Chapter 14: Controlling and Monitoring Access

Comparing Access Control Models

- Subject?
- Object?
- What was the last chapter about?

Comparing Access Control Models

- Subject – active entity that accesses a passive object
- Object – passive entity that provides information to active subjects
- After authenticating subjects, now we need to focus on access

Permissions, Rights, & Privileges

- Permissions?
- Rights?
- Privileges?

Understanding Authorization

- Implicit Deny
- Access Control Matrix
- Capability List
- Constrained Interface
- Content-Dependent Control
- Context-Dependent Control

Understanding Authorization

- Need to Know
- Least Privilege
- Separation of Duties and Responsibilities

Defining Requirements – Security

- What is a security policy?

Introducing Access Control Models

- Discretionary Access Control
- Role-Based Access Control (RBAC)
- Rule-Based Access Control
- Attribute-Based Access Control (ABAC)
- Mandatory Access Control (MAC)
- Risk-Based Access Control

Discretionary Access Control

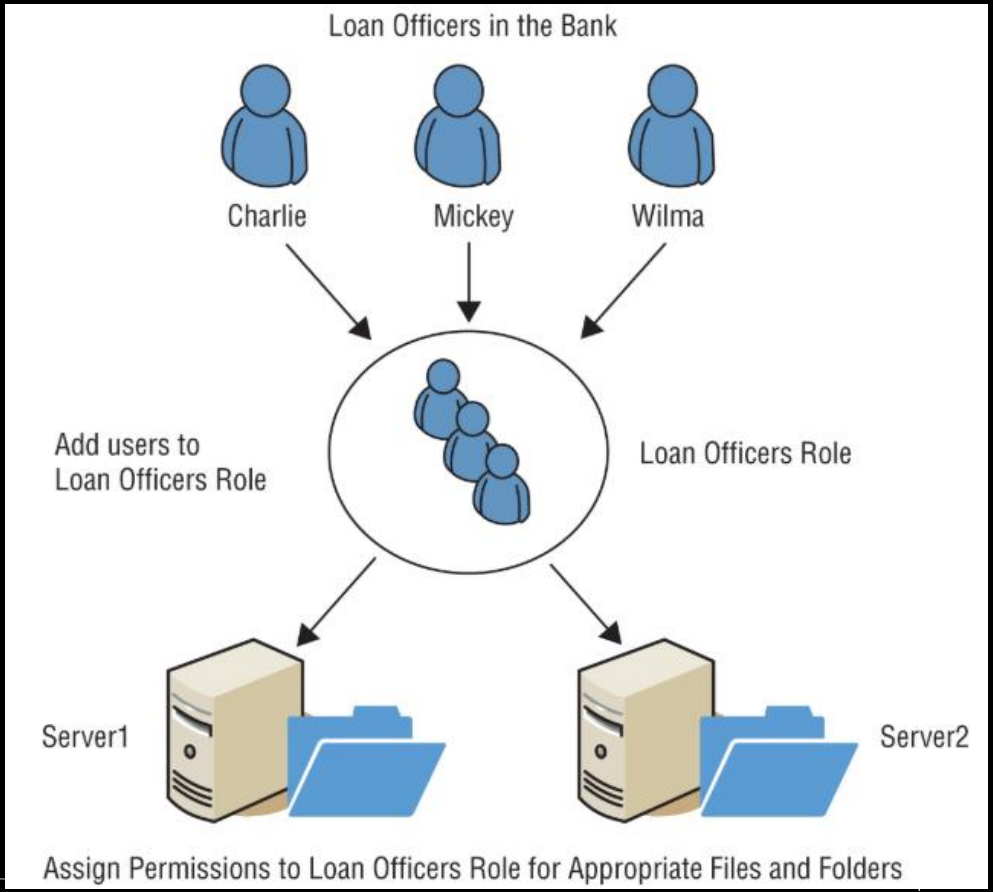
- What is it?
- Is there something you can see this being used in?

Nondiscretionary Access Control

- What is it?
- Why is this different from discretionary access control?

Role-Based Access Control

- Pros?
- Any Issues?



Rule-Based Access Control

- Rules, restriction, and filters
- Any idea what this is used in?

Attribute-Based Access Control

- Characteristic of users, the network, and devices
- Any idea what this is used in?

Mandatory Access Control (MAC)

- Classification labels

Lentil	Foil	Crimson	Matterhorn	Confidential
Domino	Primrose	Sleuth	Potluck	Private
				Sensitive
				Public

Mandatory Access Control (MAC)

- Hierarchical Environment
- Compartmentalized Environment
- Hybrid Environment

Risk-Based Access Control

- Relatively New
  - Environment
  - Situation
  - Security policies
- Multifactor Authentication
- Compliant Mobile Devices

Implementing Authentication Systems

- Implementing SSO on the Internet
  - XML
  - SAML
  - OAuth
  - OpenID Connect

Comparing SAML, OAuth, OpenID

- SAML
  - SAML 2.0 is an open XML-based standard
  - OASIS adopted it as a standard in 2005
  - It utilizes three entities: a principal (such as a user), a service provider (such as a website), and an identity provider (a third party that holds the authentication and authorization information)
  - It can provide authentication, authorization, and attribute information on the principal.

Comparing SAML, OAuth, OpenID

- OAuth
  - It's an authorization framework, not an authentication protocol
  - RFC 6749 describes OAuth 2.0
  - It exchanges information using APIs
  - An app obtains an access token from an identity provider
  - Later, the app includes the access token for authorization

Comparing SAML, OAuth, OpenID

- OpenID Connect
  - OIDC is an authentication layer using OAuth 2.0
  - It provides both authentication and authorization
  - It builds on OpenID (a deprecated standard) but uses a JSON Web Token

Implementing SSO Internal Networks

- AAA Protocols
- VPNs
- NASs
- Etc

Implementing SSO Internal Networks

- Kerberos
  - Key Distribution Center
  - Kerberos Authentication Server
  - Ticket
  - Ticket-Granting Ticket
  - Kerberos Principal
  - Kerberos Realm

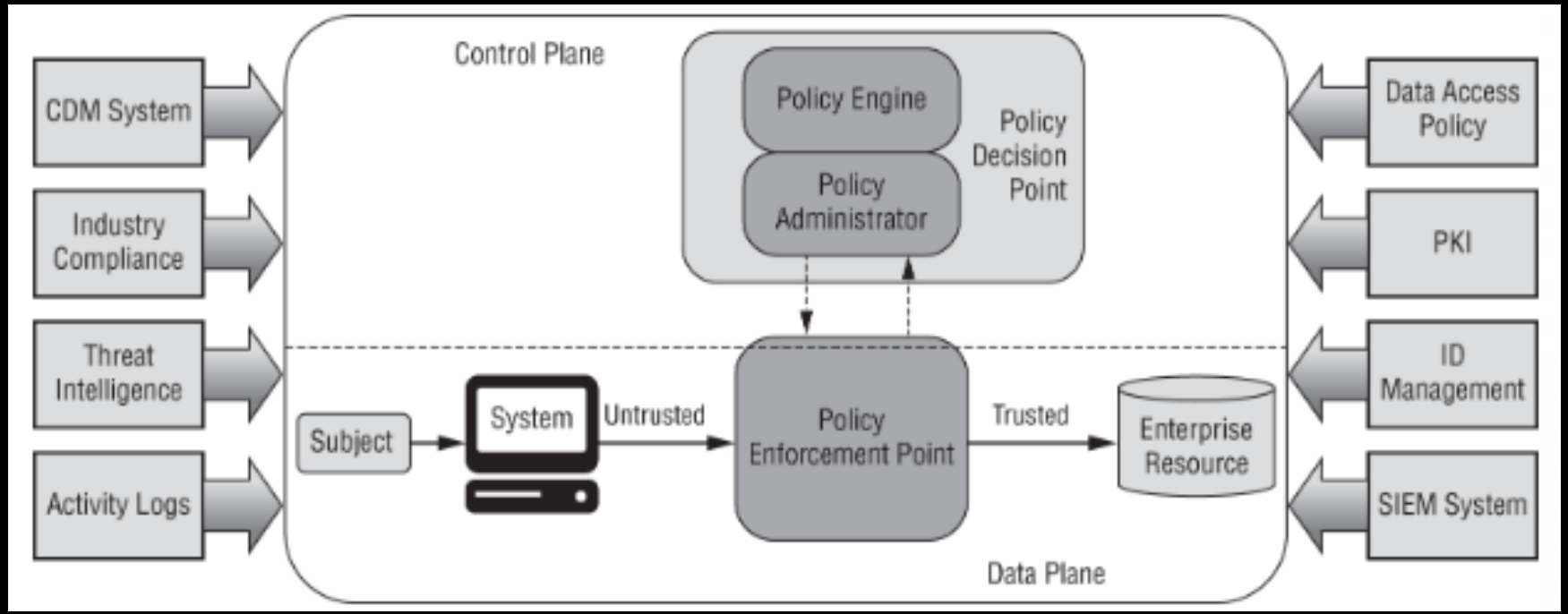
Implementing SSO Internal Networks

- Remote Authentication Dial-In User Service (RADIUS)
- TACACS+

Zero-Trust Access Policy Enforcement

- What is Zero-Trust?

Zero-Trust Access Policy Enforcement



Understanding Access Control Attacks

- Privilege Escalation
- Using the su and sudo commands
- PowerShell
- Password Attacks
- Dictionary Attacks
- Brute-Force Attacks

Understanding Access Control Attacks

- Spraying Attacks
- Credential Stuffing Attacks
- Birthday Attacks
- Rainbow Table Attacks
- Mimikatz
- Pass-the-Hash Attacks

Understanding Access Control Attacks

- Overpass the Hash
- Pass the Ticket
- Silver Ticket
- Golden Ticket
- Kerberos Brute Force
- ASREPRoast

Understanding Access Control Attacks

- Kerberoasting
- Sniffer Attacks
- Spoofing Attacks

Core Protection Methods

- Control Physical Access to Systems
- Control Electronic Access to Files
- Hash and Salt Passwords
- Use Password Masking
- Deploy MFA
- Account Lockout

Core Protection Methods

- Use Last Logon Notification
- Educate Users about Security